

Security+ 4.6 · Identity & Access Management

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.6 — Identity & Access Management (12:46)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: IAM: account provisioning (create/config); RBAC (por função) e ABAC (por atributo); SSO (login único federado — SAML/OIDC); service account (credencial de script — gestão especial).

Highlights que a prova cobra

- RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar
- SSO: login único — reduz reuso de senha (mais seguro)

Dicas de prova & Cenários Típicos

- 'access assigned based on job role'=RBAC

Cenário clássico de exame: 'empregado de marketing só acessa arquivos da área de marketing'=RBAC.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.6 — Identity & Access Management)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **TACACS+:** Terminal Access Controller Access-Control System Plus: Protocolo AAA corporativo que opera sobre TCP porta 49, cifra o pacote inteiro e separa autenticação de autorização, permitindo controle comando a comando em roteadores e switches.
- **RADIUS:** Remote Authentication Dial-In User Service: Protocolo AAA cliente-servidor (UDP 1812/1813) amplamente usado em redes 802.1X e VPNs; criptografa apenas o campo da senha e combina autenticação com autorização.
- **KERBEROS:** Protocolo de autenticação padrão do Active Directory baseado em tickets criptografados emitidos pelo KDC (Key Distribution Center: AS e TGS), prevenindo senhas em texto claro na rede.
- **LDAP:** Lightweight Directory Access Protocol: Protocolo de consulta a árvores de diretório (porta TCP 389 em texto claro).
- **RBAC:** Role-Based Access Control: Modelo de controle de acesso onde as permissões são atribuídas a funções/papéis do cargo (roles), e não aos indivíduos diretamente.
- **ABAC:** Attribute-Based Access Control: Modelo de controle de acesso mais dinâmico que avalia atributos do usuário, do recurso, da ação e do ambiente (horário, localização, dispositivo).
- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?

- A)** Senha, PIN e resposta secreta
- B)** Algo que sabe, algo que tem, algo que é
- C)** 3 senhas diferentes
- D)** Usuário, senha e e-mail

2. O serviço que controla QUEM pode acessar O QUÊ na nuvem (usuários, papéis, permissões) é o:

- A)** CDN
- B)** IAM
- C)** VPN
- D)** DNS

3. Qual protocolo de autenticação utiliza tickets e é amplamente usado em ambientes Active Directory?

- A)** RADIUS
- B)** TACACS+
- C)** Kerberos
- D)** LDAP

4. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'SSO: login único — reduz reuso de senha (mais seguro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)...

6. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'access assigned based on job role'=RBAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'access assigned based on job role'=RBAC...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'empregado de marketing só acessa arquivos da área de marketing'=RBAC.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'empregado de marketing só acessa arquivos da área de marketing'=RBAC....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar...

9. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'SSO: login único — reduz reuso de senha (mais seguro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'access assigned based on job role'=RBAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'access assigned based on job role'=RBAC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Algo que sabe, algo que tem, algo que é.

✓ **Por que está certa:** A autenticação multifator (MFA) exige a combinação de pelo menos dois fatores de categorias distintas. As três categorias clássicas são: algo que você sabe (conhecimento, como senha ou PIN), algo que você tem (posse, como token físico ou aplicativo gerador de código) e algo que você é (inerência, como impressão digital ou reconhecimento facial). A opção 'Algo que sabe, algo que tem, algo que é' é a única que elenca corretamente essas três categorias, conforme definido pelo NIST SP 800-63 e pelo CompTIA Security+ SY0-701. MFA é um controle de acesso que mitiga riscos de comprometimento de credenciais, pois um atacante precisaria superar múltiplas barreiras independentes.

✗ **Por que as outras estão erradas:**

- *Senha, PIN e resposta secreta:* Senha, PIN e resposta secreta são todos exemplos de 'algo que você sabe' (fator de conhecimento). Embora sejam mecanismos de autenticação, eles pertencem à mesma categoria, portanto não constituem MFA verdadeiro. O uso de múltiplos segredos do mesmo tipo é chamado de autenticação multi-passo ou multifator aparente, mas não atende à exigência de categorias distintas. Além disso, respostas secretas são frequentemente vulneráveis a ataques de engenharia social e podem ser descobertas, não oferecendo o mesmo nível de segurança que um segundo fator de categoria diferente.
- *3 senhas diferentes:* Três senhas diferentes continuam sendo apenas um fator de conhecimento. A repetição de senhas não adiciona uma nova categoria de autenticação; apenas aumenta a complexidade da mesma categoria. Isso não é MFA, pois um atacante que comprometa o mecanismo de captura de senhas (por exemplo, keylogger ou phishing) pode obter todas as três. A segurança não é multiplicada pela quantidade de senhas, mas pela diversidade de fatores. O CompTIA Security+ enfatiza que MFA requer fatores de tipos diferentes, não múltiplas instâncias do mesmo tipo.
- *Usuário, senha e e-mail:* Usuário e e-mail são identificadores, não fatores de autenticação. O nome de usuário e o endereço de e-mail são públicos ou facilmente descobertos e não provam identidade. A senha é um fator de conhecimento, mas os outros dois não são fatores de autenticação. Portanto, essa combinação não representa MFA. Além disso, o e-mail pode ser usado como canal para envio de códigos, mas por si só não é um fator; ele é um meio de transporte. A definição formal de MFA exige que cada fator seja de uma categoria diferente (conhecimento, posse, inerência), e aqui só há um fator real.

2) B — IAM.

✓ **Por que está certa:** O IAM (Identity and Access Management) é o serviço que gerencia identidades, autenticação e autorização na nuvem. Ele controla QUEM pode acessar O QUÊ, definindo usuários, grupos, papéis (roles), políticas de permissão e condições de acesso. No syllabus da CompTIA Security+ SY0-701, o IAM é apresentado como o pilar para aplicar o princípio do menor privilégio, segregação de funções e autenticação multifator. Serviços como AWS IAM, Azure AD (Entra ID) e Google Cloud IAM permitem criar políticas granulares que especificam ações permitidas ou negadas sobre recursos específicos, sendo a resposta exata para o controle de acesso na nuvem.

✗ **Por que as outras estão erradas:**

- *CDN:* CDN (Content Delivery Network) é uma rede de servidores distribuídos geograficamente para entregar conteúdo estático e dinâmico com baixa latência, como imagens, vídeos e arquivos. Ela melhora desempenho e disponibilidade, mas não gerencia identidades, papéis ou permissões. Não controla quem acessa o quê; apenas otimiza a entrega de conteúdo. Portanto, é totalmente

inaplicável ao problema de controle de acesso lógico descrito no enunciado.

- **VPN:** VPN (Virtual Private Network) estabelece um túnel criptografado para proteger a comunicação entre um dispositivo e uma rede, garantindo confidencialidade e integridade do tráfego. Embora possa ser usada como parte de uma estratégia de acesso remoto seguro, ela não define quem pode acessar quais recursos na nuvem. A VPN autentica o túnel, mas não gerencia permissões granulares sobre serviços e dados. O controle de acesso a recursos específicos é função do IAM, não da VPN.
- **DNS:** DNS (Domain Name System) traduz nomes de domínio em endereços IP, permitindo a localização de serviços na internet. Ele é fundamental para a resolução de nomes, mas não tem qualquer relação com autenticação, autorização ou gestão de identidades. Não controla quem acessa o quê; apenas resolve nomes. Confundir DNS com IAM é um erro categórico, pois operam em camadas completamente distintas do modelo OSI e de segurança.

3) C — Kerberos.

✓ **Por que está certa:** O **Kerberos** é um protocolo de autenticação baseado em tickets, amplamente utilizado em ambientes Active Directory (AD) da Microsoft. Ele utiliza criptografia simétrica e um Centro de Distribuição de Chaves (KDC) para autenticar usuários e serviços sem transmitir senhas pela rede. O processo envolve a obtenção de um Ticket Granting Ticket (TGT) e, posteriormente, tickets de serviço para acessar recursos. No syllabus da CompTIA Security+ (SY0-701), Kerberos é destacado como o protocolo de autenticação padrão em domínios Windows, oferecendo autenticação mútua e suporte a single sign-on (SSO). A menção a 'tickets' e 'Active Directory' aponta diretamente para Kerberos.

✗ Por que as outras estão erradas:

- **RADIUS:** RADIUS (Remote Authentication Dial-In User Service) é um protocolo de autenticação, autorização e contabilização (AAA) usado principalmente para acesso remoto a redes, como VPNs, Wi-Fi corporativo e conexões dial-up. Ele não utiliza tickets; em vez disso, emprega um modelo cliente-servidor com atributos e desafios (como PAP, CHAP, EAP). Embora possa integrar-se ao Active Directory para validar credenciais, não é o protocolo nativo de autenticação do AD e não se baseia em tickets. Portanto, não corresponde à descrição.
- **TACACS+:** TACACS+ (Terminal Access Controller Access-Control System Plus) é um protocolo AAA desenvolvido pela Cisco, usado para autenticação, autorização e accounting de dispositivos de rede (roteadores, switches). Ele separa as funções AAA e criptografa todo o payload, mas não utiliza tickets e não é o mecanismo de autenticação padrão do Active Directory. Seu foco é o gerenciamento de acesso a equipamentos de infraestrutura, não a autenticação de usuários em domínios Windows. Logo, está incorreto para o contexto apresentado.
- **LDAP:** LDAP (Lightweight Directory Access Protocol) é um protocolo de acesso a serviços de diretório, como o Active Directory, permitindo consultas e modificações em objetos (usuários, grupos, computadores). Ele é usado para leitura e escrita no diretório, mas não é um protocolo de autenticação baseado em tickets. A autenticação no AD geralmente ocorre via Kerberos ou NTLM; o LDAP pode ser usado para autenticação simples (bind), mas não emprega tickets e não é o mecanismo principal de autenticação em ambientes AD. Portanto, não atende à descrição de 'utiliza tickets'.

4) B — Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): SSO: login único — reduz reuso de senha (mais seguro).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'access assigned based on job role'=RBAC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'empregado de marketing só acessa arquivos da área de marketing'=RBAC.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'empregado de marketing só acessa arquivos da área de marketing'=RBAC..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): SSO: login único — reduz reuso de senha (mais seguro).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: 'access assigned based on job role'=RBAC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.